哈爾濱工業大學
HARBIN INSTITUTE OF TECHNOLOGY

密码学原理

Cryptography Principles

第3讲：计算安全

刘广睿
哈尔滨工业大学 计算学部

2025秋

邮箱：grliu@hit.edu.cn
主页：homepage.hit.edu.cn/liuguangrui
博客：liuguangrui.top

上节回顾

CONTENTES

回顾

#01 完美保密

#02 一次一密

#03 香农定理

攻击场景

敌手（Adv）的能力有多强？敌手知道多少信息？

Ciphertext-only (COA) 唯密文:攻击者只知道密文，实现将目标密文破译为对应的明文

Known-plaintext (KPA) 已知明文:攻击者知道有限的明文-密文对，实现破译目标密文

Chosen-plaintext (CPA) 选择明文:攻击者任意构造明文，可以得到对应密文，实现破译目标密文

Chosen-ciphertext (CCA) 选择密文:攻击者任意构造密文，可以得到对应明文，实现破译目标密文（构造密文不包含目标密文 ）

完美保密

密文中没有任何明文信息：根据密文来猜测和不知道密文来猜测是一样的

$$\Pr[M = m | C = c] = \Pr[M = m]$$

密文分布独立：即不论明文是什么，都不影响密文出现的概率

$$\Pr[C = c \mid M = m_0] = \Pr[C = c \mid M = m_1]$$

不可区分性：给定2个明文与1个密文，无法判定密文是由哪个明文加密得到的

$$\Pr[C = c \mid M = m] = \Pr[C = c]$$

一比特异或加密

下方方案是否具有完善保密性？

对于$\mathcal{M} = \mathcal{K} = \{0,1\}, \mathrm{Enc}_k(m) = m \oplus k.$

一比特异或加密具有完善保密性。

令$\Pr[M = 1] = p$ 且$\Pr[M = 0] = 1 - p$。我们考虑 $M = 1$ 且 $C = 1$ 的情况:

$$\Pr[M = 1|C = 1] = \Pr[C = 1|M = 1] \cdot \Pr[M = 1]/\Pr[C = 1]$$

$$= \frac{\Pr[K = 1 \oplus 1] \cdot}{\Pr[C = 1|M = 1] \cdot \Pr[M = 1] + \Pr[C = 1|M = 0] \cdot \Pr[M = 0]}$$

$$= \frac{\frac{1}{2} \cdot}{\frac{1}{2} \cdot + \frac{1}{2} \cdot (1 - p)} = p = \Pr[M = 1]$$

对于其他情况，我们可以进行同样的推导。

注意: $\Pr[M = 1|C = 1] \neq \Pr[M' = 1C = 1] = \Pr[C = 1|M = 1] \cdot \Pr[M = 1] = \frac{1}{2} \cdot$ 。

一次一密

- $\mathcal{M} = \mathcal{K} = \mathcal{C} = \{0,1\}^{\ell}$.
- Gen 以恰好为 $2^{-\ell}$ 的概率随机选择一个密钥 k。
- $c := \mathrm{Enc}_k(m) = k \oplus m$.
- $m := \mathrm{Dec}_k(c) = k \oplus c$.

定理 3

一次一密是完善保密加密

证明

选定明文空间$\mathcal{M}$上的分布，选定任意一个$m \in \mathcal{M}, c \in \mathcal{C}$。“一次一密”有

$$\Pr[C = c \mid M = m] = \Pr[M \oplus K = c \mid M = m]$$
$$= \Pr[m \oplus K = c] = \Pr[K = m \oplus c] = \frac{1}{2^l}$$

由于这对所有分布和所有m都成立，所以对于任意$\mathcal{M}$上的概率分布，每$m_0, m_1 \in \mathcal{M}$和每个$c \in \mathcal{C}$满足

$$\Pr[C = c \mid M = m_0] = \frac{1}{2^l} = \Pr[C = c \mid M = m_1]$$

根据引理3,这意味着一次一密是完善保密加密。

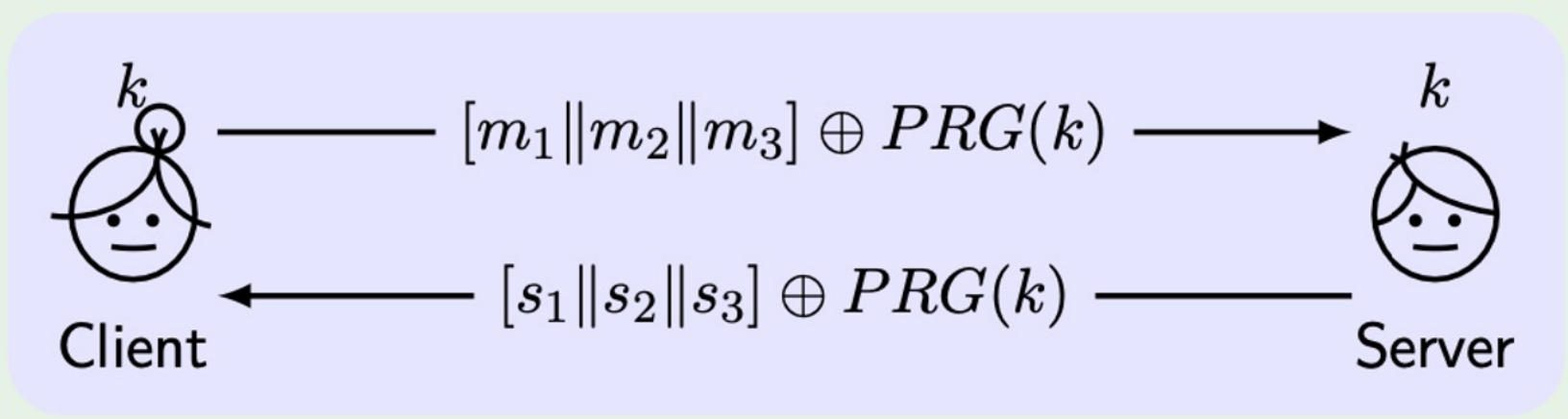
一次一密重复使用密钥的后果

（该方案）仅能在同一密钥下使用一次，否则：

$$c \oplus c' = (m \oplus k) \oplus (m' \oplus k) = m \oplus m'$$

由于语言本身的冗余性，攻击者可以从 $m \oplus m'$ 中推断出 m 的信息。

MS-PPTP (Windows NT) 的例子：



改进方案： 在客户端到服务器与服务器到客户端的通信中，分别使用不同的密钥。

香农定理

$$\text{完美保密} \quad \Rightarrow \quad |\mathcal{K}| \geq |\mathcal{M}|$$

香农定理：如果一个保密算法满足完美保密，则其密钥空间不能比明文空间小。

对于一次一密来说，密钥长度需要大于等于明文长度。

完美保密局限性

Limitation·01

密钥的配送

安全配送超长密钥难度过大

Limitation ·02

密钥的保存

难以无法错备份至少与明文等长的密钥

Limitation ·03

密钥的生成

计算机无法生成真随机数

CONTENTES

目录

#01 计算安全

#02 伪随机数

#03 规约证明

#04 计算安全加密方案

课程内容

	第一部分 (4学时) 密码学基本概念	第二部分 (12学时) 对称加密	第三部分 (12学时) 非对称加密	第四部分 (4学时) 密码学协议
课堂讲授	**密码学安全思维** 古典密码学 可证明安全 开放密码学 香农定理	**私钥安全定义** 唯密文攻击 已知明文攻击 选择明文攻击 **私钥数学基础** 伪随机生成器 伪随机函数 伪随机排列 随机预言机 规约证明 **私钥密码学体制** 分组密码 操作模式 消息认证码 认证加密 哈希函数	**公钥安全定义** 选择密文攻击 选择消息攻击 旁路攻击 **公钥数学基础** 整数分解 离散对数 椭圆曲线 单项函数 陷门函数 **公钥密码学体制** 公钥加密 RSA 密钥交换 数字签名 PKI证书	**密码学原理应用** 三次传递 互锁协议 盲签名 秘密分享 零知识证明 多方安全计算 同态加密 量子密钥分发
实验教学	实验一 (2学时) 一次一密实现与为随机生成	实验二 (2学时) 对称加密与消息认证实现	实验三 (2学时) 公钥加密与数字证书实现	实验四 (2学时) HTTPS网站的Web PKI部署

#01
计算安全

完美保密局限性

一次一密符合完美保密要求

- $\mathcal{M} = \mathcal{K} = \mathcal{C} = \{0,1\}^{\ell}$.
- Gen 以恰好为 $2^{-\ell}$ 的概率随机选择一个密钥 k。
- $c := \mathrm{Enc}_k(m) = k \oplus m$.
- $m := \mathrm{Dec}_k(c) = k \oplus c$.

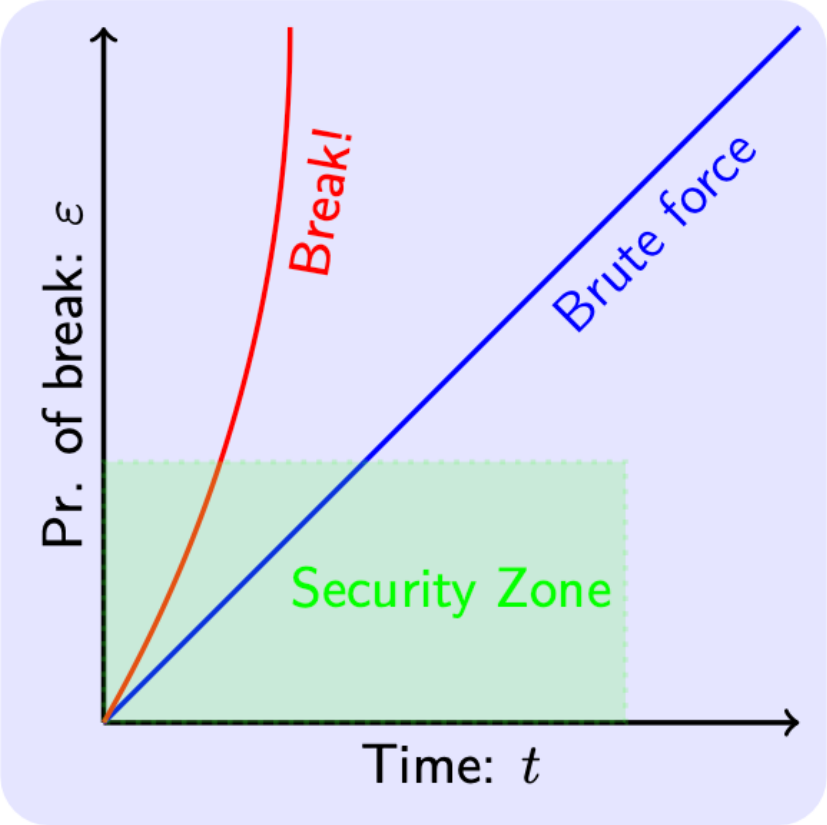
完美保密/一次一密难以实际应用

密钥长度：完美保密的密钥需要很长，传输代价过高，且如果密钥不够长，则不能达到完美保密。

密钥随机性：一次一密的密钥要求真随机生成，计算代价过高，甚至不可能实现。

如何使完美保密/一次一密可实际应用？

计算安全思想



计算安全：
敌手拥有有限的时间t来破解
以小到可忽略的概率P成功破解

完美保密/信息论安全：
数学理论上不可破解

计算安全/语义安全：
现实实践上不可破解

计算安全放松了安全条件来追求实践中的安全，使得密钥可以很短，实践更可行

有限的时间与可忽略的概率

有限时间：破解算法是多项式时间的（polynomial time, PT），即对于任意输入n，破译算法都在多项式步骤$p(\cdot)$内结束$(p(n) = a \times n^b)$

可忽略概率：一个函数f是可忽略的（negligible, negl），若对于任意多项式$p(\cdot)$，存在一个N使得对于所有整数$n > N$，$f(n) < 1/p(n)$

指数复杂性：（2^n）是大到不可行的；$1/2^n$是小到可忽略的

不可区分性实验

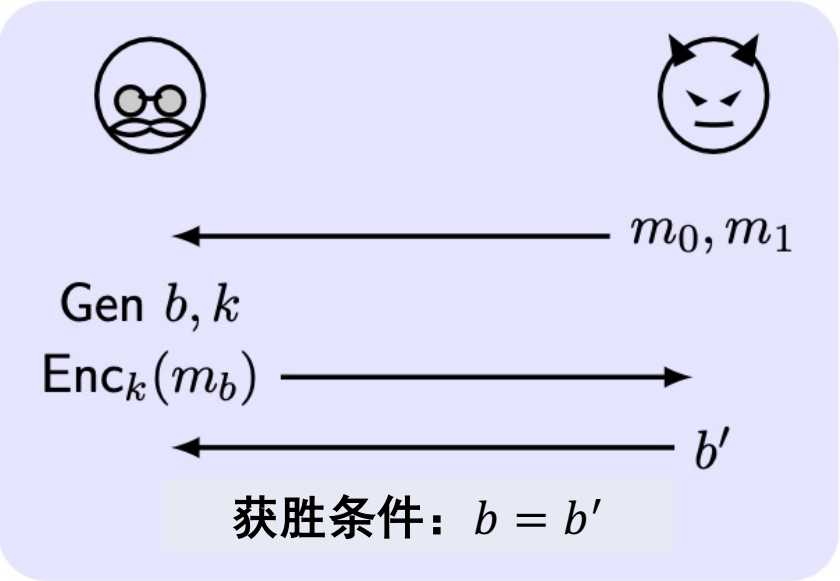
1.敌手根据安全参数1^n(n为密钥长度)产生两个相同长度的不同消息m_0, m_1，并发送给挑战者。

2.挑战者根据安全参数1^n生成密钥k，并对随机选择的一个消息进行加密,得到挑战密文c，将挑战密文c发送给敌手。

3.敌手输出一个比特，来表示对被加密消息的猜测，若猜对，则实验成功。否则，实验失败。

窃听不可区分实验 $\mathrm{PrivK}^{\mathrm{eav}}_{A,\Pi}(n)$

1. 给定输入 1^n 给敌手 $\mathcal{A}$，$\mathcal{A}$ 输出一对长度相等的消息 m_0, m_1。
2. 运行密钥生成算法 Gen(1^n) 生成一个密钥 k，选择一个随机比特 $b \leftarrow \{0, 1\}$。计算密文 $c \leftarrow Enc_k(m_b)$ 并将其交给 $\mathcal{A}$。此密文 c 称为挑战密文。
3. A 输出一个比特 b'。
4. 该实验的输出定义为：如果 $b' = b$，则输出 1；否则输出 0。若 $\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n) = 1$，则称敌手 $\mathcal{A}$ 成功。



如何判定攻击者是否有能力破译？

计算安全定义

判定敌手在唯密文攻击（窃听攻击）场景下没有区分加密结果的能力：
对于任意概率多项式时间（ probabilistic polynomial time, PPT）的敌手，不可区分实验成功概率与1/2相比是可忽略的

定义1

如果对于所有的概率多项式时间敌手 $\mathcal{A}$，存在一个可忽略函数 negl，使得：

$$\Pr\left[\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\mathrm{n}}(n) = 1\right] \leqslant \frac{1}{2} + \mathrm{negl}(n)$$

其中概率取自 $\mathcal{A}$ 所使用的随机数，则称加密方案 Π 在窃听者存在时具有不可区分的加密。

语义安全定义

定理3：
在唯密文攻击场景下，对于任意私钥加密方案，拥有计算安全性（加密结果不可区分）等价于拥有语义安全性

完美保密：密文中没有任何明文信息

语义安全：密文中没有任何明文的有意义信息

定义2

如果对于所有概率多项式时间敌手 A，都存在一个概率多项式时间敌手 A'，使得对于所有分布 $X = (X_1, \ldots)$ 和所有函数 f, h，满足：

$$\left|\Pr[\mathcal{A}(1^n, \mathrm{Enc}_k(m), h(m)) = f(m)] - \Pr\left[\mathcal{A}'\left(1^n, h(m)\right) = f(m)\right]\right| \leq \mathrm{negl}(n).$$

其中 m 根据分布 X_n 选取，$h(m)$ 是外部信息，则称加密方案 Π 在窃听者存在时是**语义安全**的。

定理 3

一个私钥加密方案在窃听者存在时具有**不可区分**的加密，当且仅当它在窃听者存在时是**语义安全**的。

课堂练习（计算安全）

1.一次一密方案在出现窃听者时是否是不可区分的？

2.若一个敌手一直在实验中失败，该方案是安全的吗？

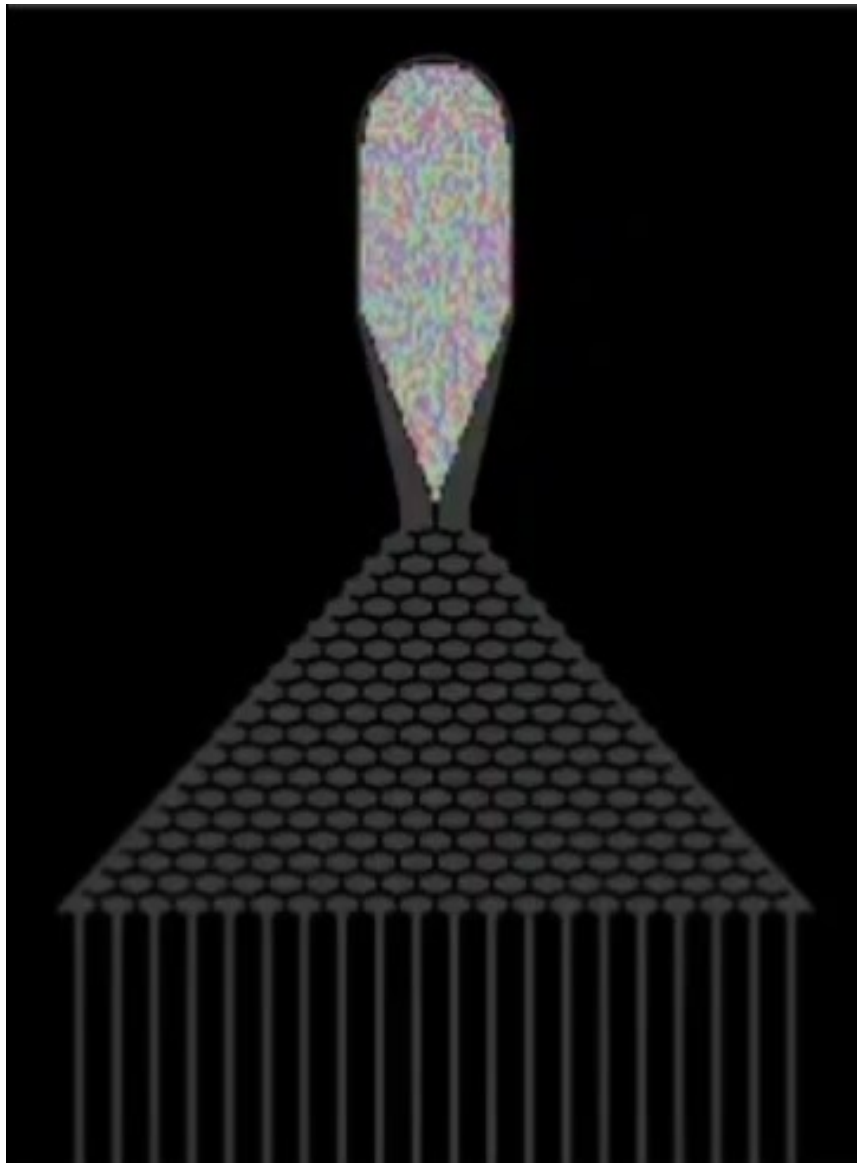
3.若从密文中猜测到消息中最低比特的概率是3/4，该方案是安全的吗？

4.相关性：X和Z的分布不可区分，Y和Z的分布不可区分，那么X和Y的分布是不可区分的吗？

#02
伪随机数

真随机与伪随机

什么是随机的？



程序模拟高尔顿板

高尔顿板录像视频

真随机与伪随机

你能区分哪个是真随机产生的结果吗？

高尔顿板实验结果1

槽号	球数	百分比
0	2	0.2
1	10	1.0
2	41	4.1
3	95	9.5
4	182	18.2
5	230	23.0
6	212	21.2
7	142	14.2
8	63	6.3
9	19	1.9
10	4	0.4

高尔顿板实验结果2

槽号	球数	百分比
0	1	0.1
1	8	0.8
2	40	4.0
3	106	10.6
4	189	18.9
5	246	24.6
6	211	21.1
7	129	12.9
8	51	5.1
9	17	1.7
10	2	0.2

高尔顿板实验结果3

槽号	球数	百分比
0	2	0.2
1	9	0.9
2	39	3.9
3	106	10.6
4	197	19.7
5	253	25.3
6	208	20.8
7	126	12.6
8	45	4.5
9	13	1.3
10	2	0.2

真随机与伪随机

什么是真随机的？

类型	均匀分布性	不可预测性	不可重现性	不确定性	说明
弱伪随机数	○	×	×	×	只具备均匀分布性（不可用于密码技术）
强伪随机数	○	○	×	×	具备不可预测性（可用于密码技术）
弱真随机数	○	○	○	×	具备不可重现性（可用于密码技术）
强真随机数	○	○	○	○	具备不确定性（可用于密码技术）

伪随机性的目的

完美保密的局限性：密钥长度需要和明文一样长才安全

计算安全中放松了安全的定义，那密钥能不能短一些？
能不能放松对随机性的要求，产生足够长但不完全随机的密钥？

密码算法中的随机性需要由一个可描述的确定性机制产生
一个固定的字符串谈不上是否随机/伪随机，随机/伪随机指的是产生字符串的过程

伪随机对于不知道其机制的观察者来说看起来是真随机！

区分器统计测试

判断是否随机实践方法（缺乏理论依据）：

1.从一个随机生成器中得到多个随机序列并进行一套统计测试。
例如，序列中0和1的数量之差不应该太大，最大连续0的长度不应该太长等等。

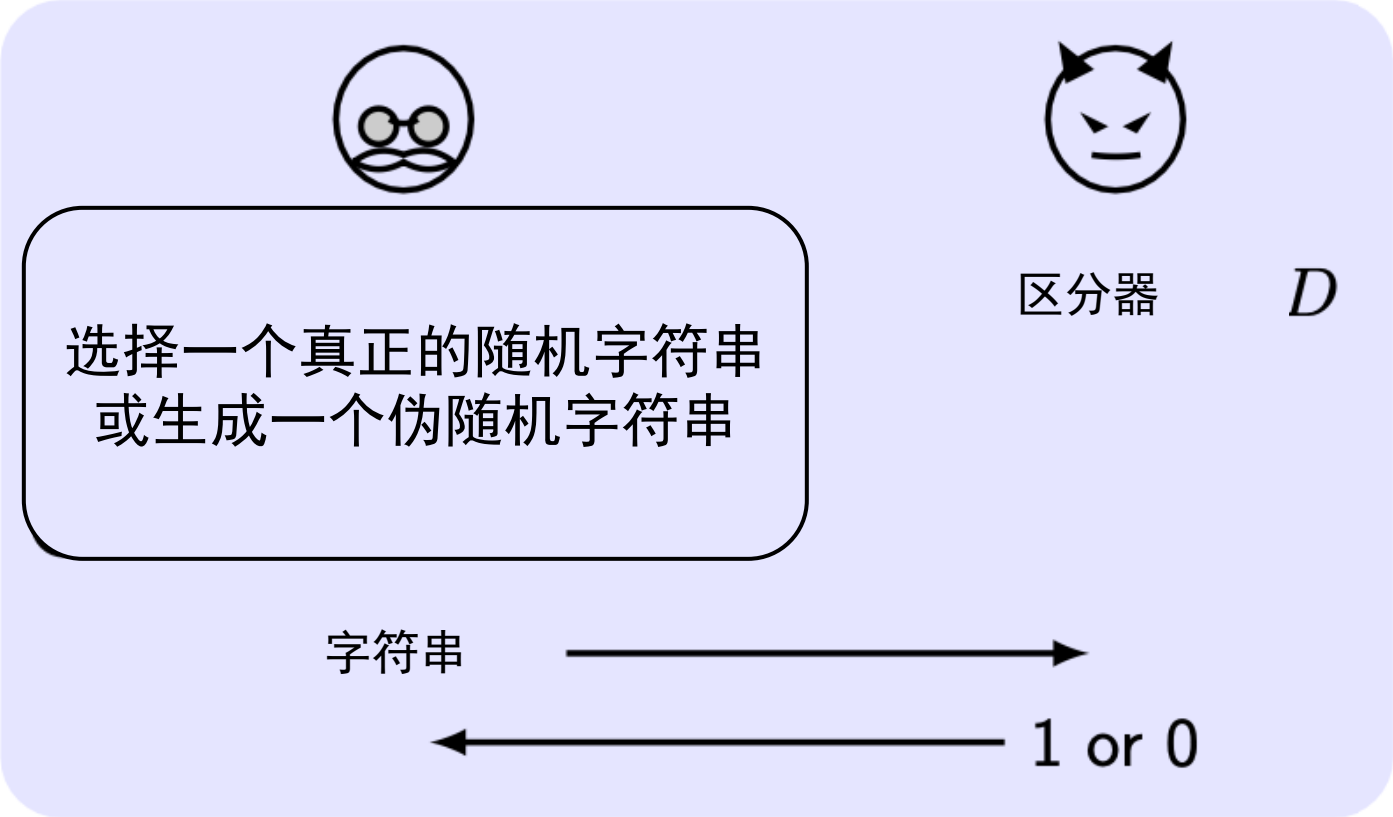
2.伪随机性意味着下一比特不可预测——姚期智。
例如，通过所有下一比特测试等且仅当通过所有统计测试。

问题是难以确定要多少测试才足够？

- $D(x) = 0$ if $|\#0(x) - \#1(x)| \leq 10 \cdot \sqrt{n}$
- $D(x) = 0$ if $|\#00(x) - n/4| \leq 10 \cdot \sqrt{n}$
- $D(x) = 0$ if max-run-of-0$(x) \leq 10 \cdot \log n$

定义伪随机性思路

直觉思路：
从一个短的真随机种子生成一个长的随机串，这个伪随机串与真随机串是不可区分的。



区分器输入一个比特串，输出1位比特

定义伪随机生成器

定义 4

一个确定性的多项式时间算法 $G: \{0,1\}^n \to \{0,1\}^{\ell(n)}$ 被称为**伪随机数生成器(PRG)**，如果它满足：

扩展性

- **扩展性：** 对于所有 n，有 $\ell(n) > n$。

伪随机

- **伪随机性：** 对于所有概率多项式时间区分器 D，满足：

$$\left|\Pr[D(r) = 1] - \Pr\left[D\left(G(s)\right) = 1\right]\right| \leq \mathrm{negl}(n)$$

均匀随机

其中 r 从 $\{0,1\}^{\ell(n)}$ 中*均匀随机*选取，**种子** s 从 $\{0,1\}^n$，中*均匀随机*选取。$\ell(\cdot)$ 是 G 的**扩展因子**。

种子

扩展因子

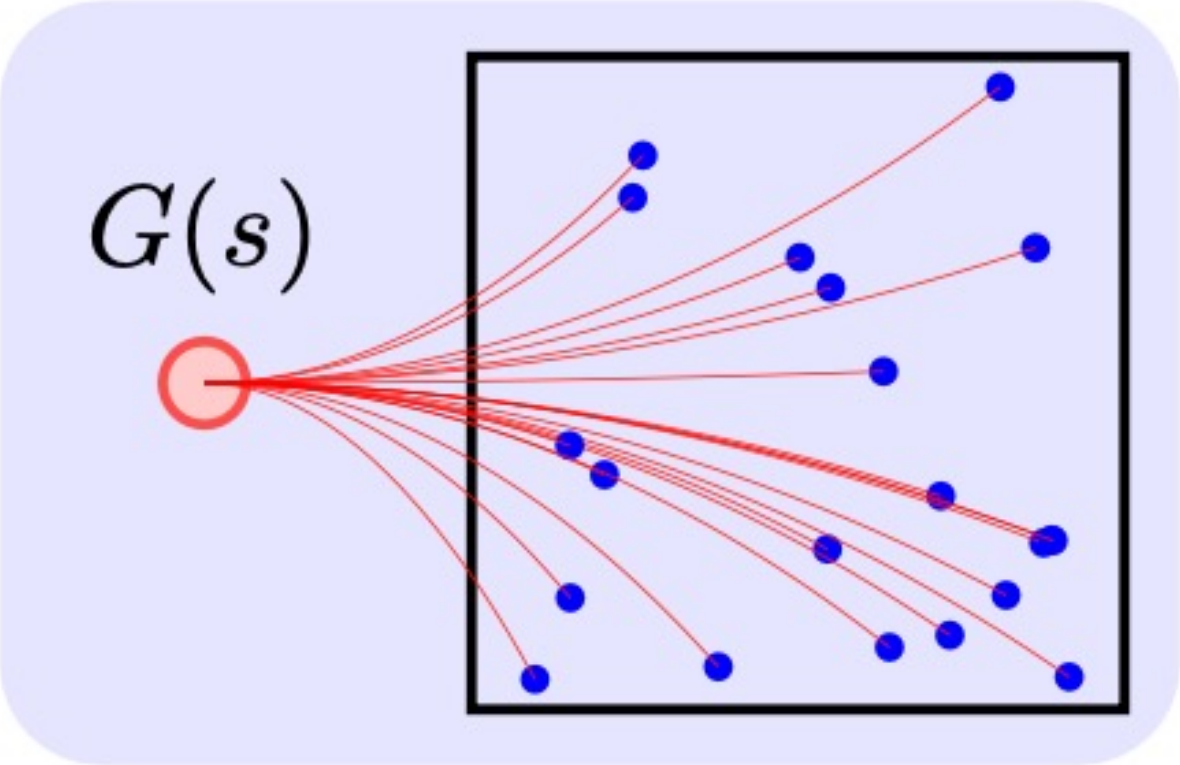
存在性： 在*单向函数*存在或 $\mathcal{P} \neq \mathcal{NP}$的弱假设下成立。

单向函数

充分种子空间原则

充分种子空间：种子必须长来抵抗蛮力攻击。

蛮力攻击：通过枚举所有种子来产生所有串，能以高概率区分出伪随机串。



真实案例

glibc random()

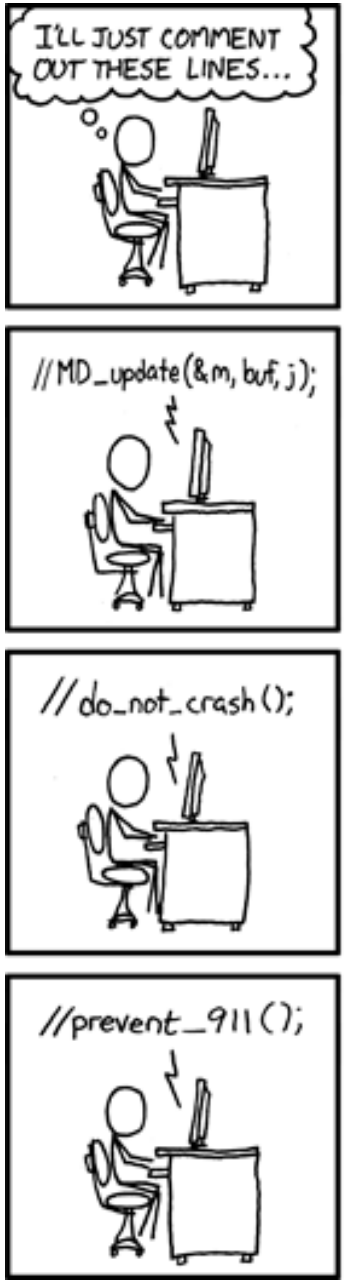
$$r[i] = (r[i-3] + r[i-31])\%2^{32}$$

Netscape (by reverse-engineering)

```
global variable seed;
RNG_CreateContext();
    (seconds, microseconds) = time of day;
    pid = process ID; ppid = parent process ID;
    a = mklcpr(microseconds);
    b = mklcpr(pid + seconds + (ppid << 12));
    seed = MD5(a, b);
RNG_GenerateRandomBytes()
    x = MD5(seed);
    seed = seed + 1;
    return x;
```

真实案例

2008年，为了避免一个编译警告，Debian的一个发布版本中误删了一行代码，引起OpenSSL中关于随机生成器的漏洞（CVE-2008-0166)。



IN THE RUSH TO CLEAN UP THE DEBIAN-OPENSSL FIASCO, A NUMBER OF OTHER MAJOR SECURITY HOLES HAVE BEEN UNCOVERED:

AFFECTED SYSTEM	SECURITY PROBLEM
FEDORA CORE	VULNERABLE TO CERTAIN DECODER RINGS
XANDROS (EEE PC)	GIVES ROOT ACCESS IF ASKED IN STERN VOICE
GENTOO	VULNERABLE TO FLATTERY
OLPC OS	VULNERABLE TO JEFF GOLDBLUM'S POWERBOOK
SLACKWARE	GIVES ROOT ACCESS IF USER SAYS ELVISH WORD FOR "FRIEND"
UBUNTU	TURNS OUT DISTRO IS ACTUALLY JUST WINDOWS VISTA WITH A FEW CUSTOM THEMES

课堂练习（伪随机数）

F is PRG. Is G PRG?

- $G(s)$ is such that $XOR(G(s)) = 1$
- $G(s) = F(s)\|0$
- $G(s) = F(s \oplus 1^{|s|})$
- $G(s) = F(s)\|F(s)$
- $G(s\|s') = F(s)\|F(s')$
- $G(s) = F(s\|0)$
- $G : s \leftarrow \{0,1\}^{20}, G(s) = F(s)$

#03
规约证明

规约证明法

规约法：将问题A'规约为另一个问题A。规约的含义即可以通过解决A来解决A'。

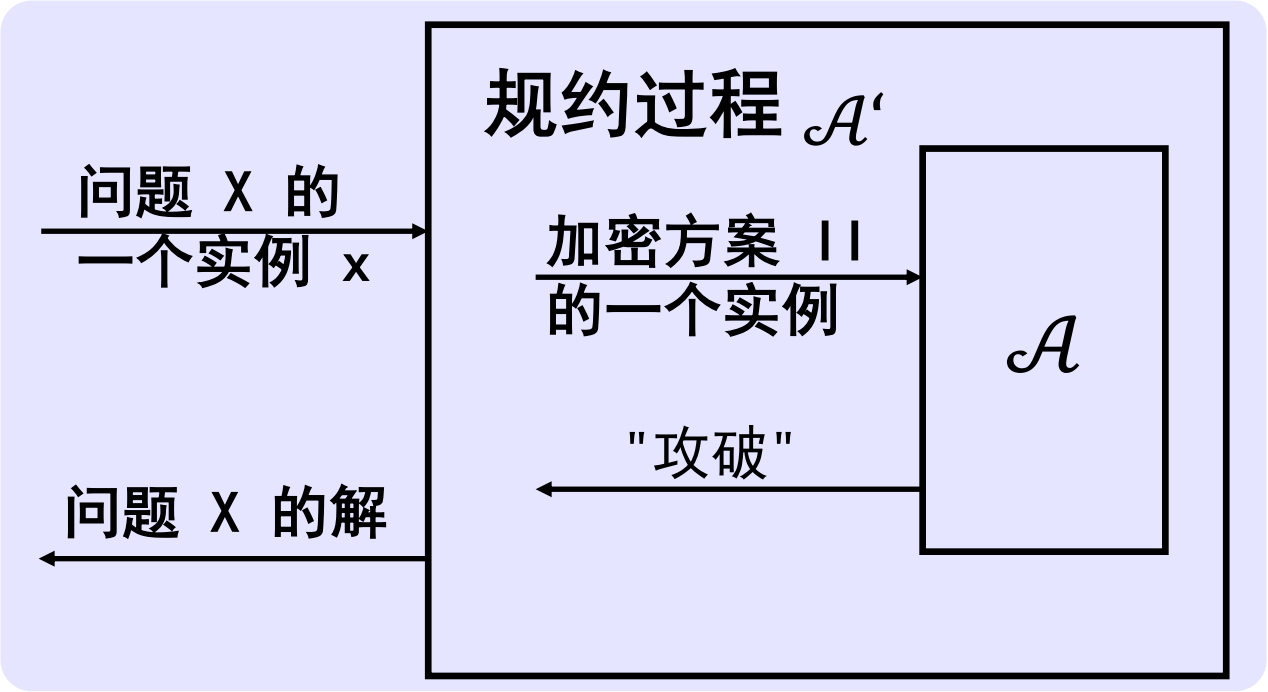
规约A'到 A：可将A'规约为A，如果A的解存在，则A'可解。可将规约理解为A'对A的子函数调用，子函数A是黑盒的（不知道A是怎么解决的），但解决A'的步骤都应该是明确的。

案例1：测量矩形面积可规约到测量矩形边长
案例2：计算一个数的平方可规约到两个数乘积，相反可以规约吗？

规约证明法

一般用于反证法：将解决“假设” 的难问题X（一般无法解决，例如P=NP）的算法A'，规约到“破解”加密方案的算法A 。

如果加密方案可以被破解，则假设的难问题也可以解决。但假设的难题无解，所以推论矛盾，则可证明加密方案不可破解



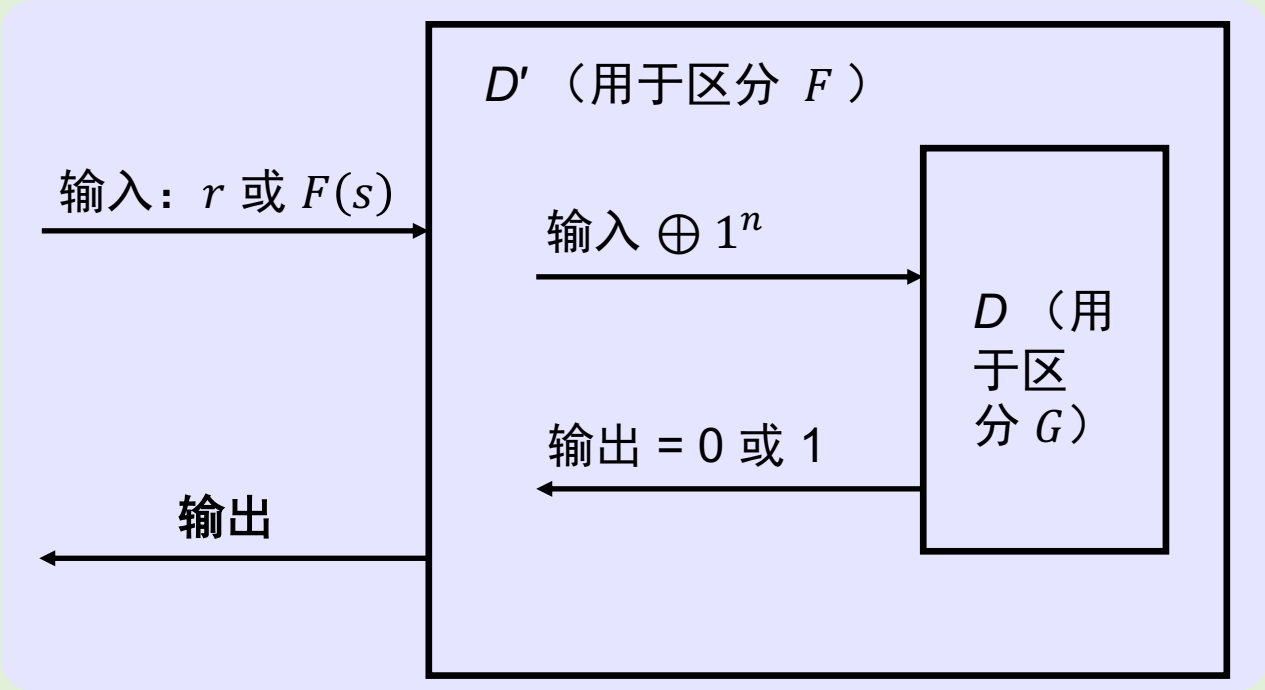
- 一个概率多项式时间敌手 A 能以概率 $\varepsilon(n)$ 攻破方案 Π。
- **假设**：问题 X 是难以解决的。
- **规约**：将 A' 规约到 A。A' 通过将 A 作为子程序运行，以 $1/p(n)$ 的概率高效地解决 x。
- **矛盾**：如果 $\varepsilon(n)$ 是不可忽略的，那么 A' 就能以不可忽略的概率 $\varepsilon(n)/p(n)$ 高效地解决难题 X。

规约证明例子

如果 $F(s)$ 是伪随机数生成器，那么 $G(s) = F(s) \oplus 1^{|n|}$ 也是吗？

- 问题 A（假设）：区分 $F(s)$ 和真正的随机数 r
- 问题 B（攻破方案）：区分 $G(s)$ 和真正的随机数 r

思路：将问题 A 规约到问题 B。既然 $F(s)$ 是可区分的，那么 $G(s)$ 也是可区分的。



规约证明例子

$$\Pr[D'(F(s)) = 1] = \Pr[D(G(s) = F(s) \oplus 1^n) = 1]$$

$$\Pr[D'(r) = 1] = \Pr[D(r \oplus 1^n) = 1] = \Pr[D(r) = 1]$$

$$\begin{aligned}\mathsf{negl} &\geq \Pr[D'(F(s)) = 1] - \Pr[D'(r) = 1] \\ &= \Pr[D(G(s)) = 1] - \Pr[D(r) = 1]\end{aligned}$$

根据 PRG 的定义，$G(s)$ 是一个伪随机数生成器。

#04

计算安全加密方案

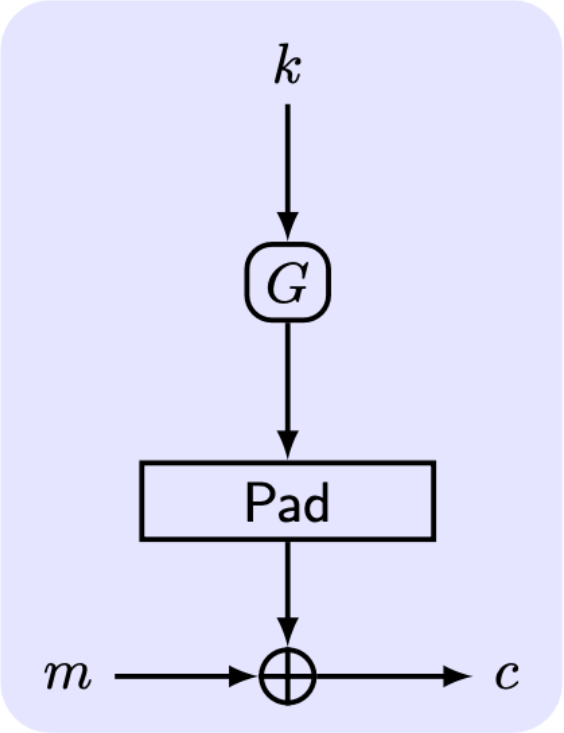
计算安全加密方案

如何改进一次一密？

一次一密的优化版本：密钥更短，用伪随机生成器生成的比特串来与明文异或。

由于敌手无法在概率多项式时间（PPT）内无法区分真随机与伪随机，所以对于敌手而言，该方案与一次一密是一样的。

由此，得到了一个计算安全加密方案，同时避免一次一密的局限性（密钥过长与真随机密钥）。



构造 5

- $|G(k)| = \ell|(k|), m \in \{0,1\}^{\ell(n)}$
- 密钥生成：$k \in \{0,1\}^{\mathrm{n}}$
- 加密：$c := G(k) \oplus m$。
- 解密：$m := G(k) \oplus c$。

定理 6

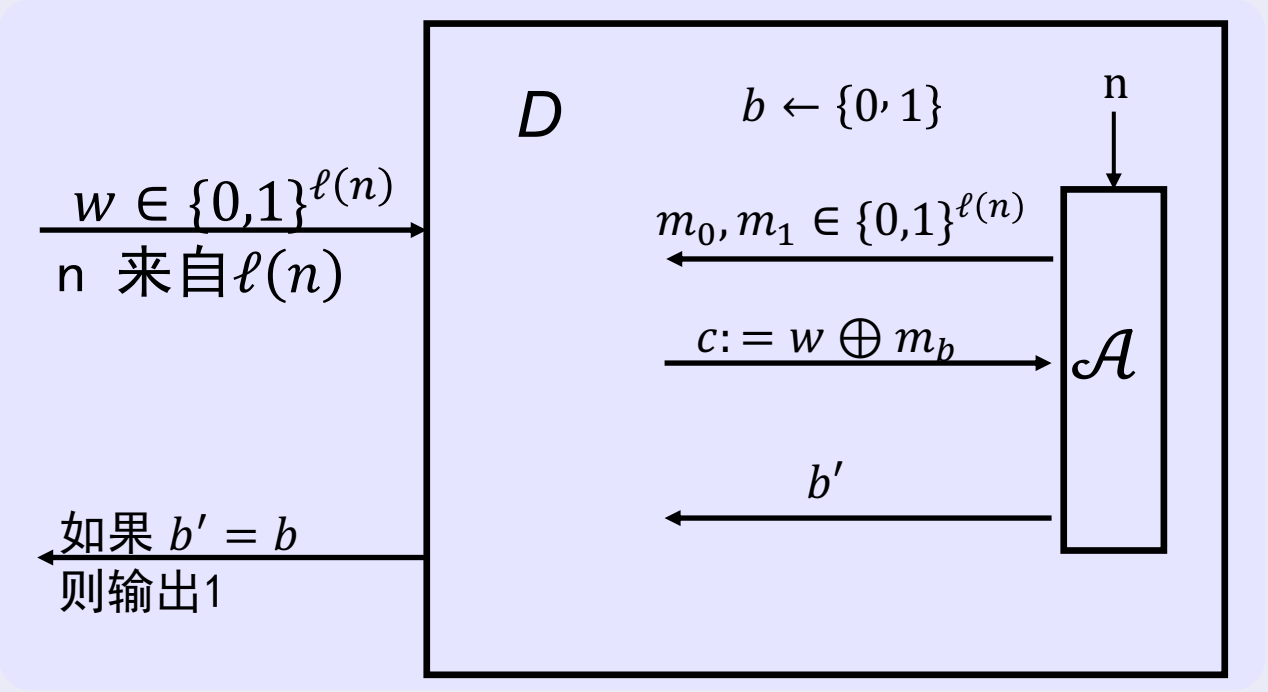
此定长加密方案在窃听者存在时具有不可区分的加密性。

计算安全性证明

规约思路：
假设难题：区分伪随机性
规约子函数：破解加密方案

证明思路：
针对伪随机生成器G的区分器D以破解敌手A为子函数，使得当敌手A破解了加密算法Π则D可以区分出G与G的伪随机性矛盾。

Proof.



$$\Pr[D(w) = 1] = \Pr\left[\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\tilde{\Pi}}(n) = 1\right]$$

□

计算安全性证明

证明

目标是证明 $\varepsilon(n) \overset{def}{=} \Pr\left[\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n) = 1\right] - \frac{1}{2}$ 是可忽略的。

(1)如果 w 是均匀随机选择的 r，那么 $\widetilde{\Pi}$ 是一次一密。

$$\Pr[D(r) = 1] = \Pr\left[\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\widetilde{\Pi}}(n) = 1\right] = \frac{1}{2};$$

(2) 如果 w 是 $G(k)$，那么 $\widetilde{\Pi} = \Pi$。

$$\Pr\left[D\big(G(k)\big) = 1\right] = \Pr\left[\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n) = 1\right] = \frac{1}{2} + \varepsilon(n)。$$

使用定义 4：

$$\left|\Pr[D(r) = 1] - \Pr\left[D\big(G(k)\big) = 1\right]\right| = \varepsilon(n) \le \mathrm{negl}(n)。$$

计算安全与完美保密对比

	计算安全	完美保密
敌手能力	概率多项式时间（PPT）窃听者	无限制窃听者
安全等级	不可区分概率为 1/2 + 可忽略项	不可区分概率严格为 1/2
随机性	伪随机性	真随机性
密钥长度	短随机串	长随机串
加密方法	异或掩码	异或掩码
证明方法	规约法	概率论证明

SUMMARY

课程小结

#01 计算安全

#02 伪随机数

#03 规约证明

#04 计算安全加密方案

PREVIEW

下节预告

#01 流密码

#02 选择明文攻击

#03 伪随机函数

#04 操作模式

哈爾濱工業大學
HARBIN INSTITUTE OF TECHNOLOGY

感谢各位同学！

欢迎交流学习

刘广睿
哈尔滨工业大学 计算学部

2025秋

邮箱：grliu@hit.edu.cn
主页：homepage.hit.edu.cn/liuguangrui
博客：liuguangrui.top